

Déclaration de Confidentialité des Données Personnelles

Les Livres de la Mer

Dernière mise à jour le 12 février 2025.

Auteur: Clément Msika.

Ce document spécifie les procédés utilisés pour la collecte des données personnelles des vendeurs et acheteurs effectuée par la boutique *Les Livres de la Mer* présente sur le site et l'application de e-commerce *Amazon France*.

Le représentant et responsable de la boutique est Clément Msika.

Le document détaille les types de données personnelles collectées via l'API d'*Amazon Selling Partner* ainsi que les finalités et mesures de sécurité liées à cette gestion de ces données.

Enfin, ce document spécifie les parties externes avec lesquelles la boutique partage les données personnelles, le responsable du traitement et les droits des utilisateurs dont les données personnelles sont collectées, stockées et analysées.

Le lecteur pourra également [se référer à la notice officielle de protection des données personnelles d'Amazon](#).

I) Cadre Juridique	1
II) Finalités d'utilisation des données personnelles	2
III) Procédés et outils techniques utilisés pour collecter, stocker et accéder de manière sécurisée aux données personnelles	3
A) Procédés de collecte et de stockage des données personnelles	3
B) Procédures d'accès aux données personnelles collectées	5
IV) Types de Données Personnelles Collectées	6
V) Parties Externes avec Lesquelles L'Organisation Partage les Données Personnelles	6
VI) Responsable du Traitement	6
VII) Droits des Utilisateurs dont Les Données Personnelles sont Collectées, Stockées et Analysées	7

I) Cadre Juridique

L'application respectera scrupuleusement les accords d'utilisation des API d'Amazon ("Amazon Services API Developer Agreement"), la Politique de Protection des données d'Amazon ("DPP") et la Politique d'Utilisation Acceptable ("AUP") dans le cadre de la réglementation applicable de protection des données. Lorsque les données sont liées à des vendeurs ou acheteurs localisés dans l'Union Européenne, la Réglementation Générale de la Protection des Données prévaudra.

Le cas échéant, les directives légales des pays et régions concernés s'appliqueront telles que le California Consumer Privacy Act (CCPA) aux Etats-Unis, le Personal Information Protection Law of the People's Republic of China.

Afin de respecter la Politique d'Utilisation Acceptable d'Amazon ("AUP"), l'application répondra aux exigences de performance, de transparence et de respect de la réglementation en vigueur.

II) Finalités d'utilisation des données personnelles

Dans le cadre de la Politique d'Utilisation Acceptable d'Amazon ("AUP"), l'application ne collectera et ne stockera les données personnelles qu'exclusivement pour réduire le délai d'envoi des commandes ou pour répondre aux obligations légales notamment en matière de taxe et régulation dans le cadre de l'intérêt légitime défini par l'article 6.1 de la RGPD.

Ces données personnelles auront été l'objet d'un consentement par l'utilisateur collecté par *Amazon*.

Le responsable de la boutique prévoit d'utiliser les données personnelles pour réduire les délais d'envoi des commandes à travers la mise en place d'alertes intégrées aux systèmes d'information externes à Amazon Selling qui permettent de réduire le délai d'emballage et d'envoi des colis.

De plus, le responsable utilisera les données personnelles pour mieux ajuster le volume d'achats de produits postaux en fonction des types de commandes et des profils clients et pourra développer des modèles de prévision des commandes et des capacités d'envoi de la librairie.

D'autre part, la collecte de données personnelles permettra de faciliter le travail de facturation et d'analyse financière de la boutique Les Livres de la Mer en combinant ces données avec la comptabilité de l'entreprise.

Le responsable de la boutique *Les Livres de la Mer* utilisera les données non personnelles pour faciliter la gestion du catalogue, des stocks et améliorer la visibilité des annonces.

III) Procédés et outils techniques utilisés pour collecter, stocker et accéder de manière sécurisée aux données personnelles

A) Procédés de collecte et de stockage des données personnelles

Le responsable de la boutique intégrera certains segments de données personnelles exposés par l'*API Selling Partner d'Amazon* dans une base de données *PostgreSQL* hébergée sur *Amazon RDS* et dans des fichiers *Google Sheet* cryptés.

Le responsable prévoit d'intégrer ces données personnelles anonymisées dans un entrepôt de données *Redshift* hébergé sur *AWS*.

Des scripts *ETL* seront prototypés avec *Sagemaker* et automatisés avec *Amazon Lambda*, *Glue* et des *Step Functions* pour automatiser l'extraction, la transformation et le stockage de ces données personnelles dans des tables de données dédiées.

Des procédures d'anonymisation et de pseudo-anonymisation des données seront implémentés pour renforcer la sécurité des données personnelles et respecter le cadre juridique détaillé ci-dessus. Les données personnelles qui pourraient être extraites via ces appels *API* seront encryptées avec des algorithmes *AES 256* et *RSA-2048* et seront l'objet d'une politique de rétention et d'archivage stricte (cf. section documentant le partage des informations pour plus de détails).

Le traitement des données de coordonnées bancaires des acheteurs respectera les *Normes de Sécurité de l'Industrie des Cartes de Paiement (PCI DSS)*.

Pour satisfaire aux exigences de la Politique de Protection des Données ("DPP"), le développeur de l'application mettra en place des pare-feux et des listes de contrôle d'accès réseau pour empêcher l'accès d'adresses IP non autorisées aux services *AWS* et *Toucan* en utilisant notamment des *VPC Amazon* et règles de contrôle des réseaux.

De plus, le responsable de l'application mettra en place un système d'encryptage de l'information en transit avec des protocoles sécurisés comme *TLS 1.2+*, *SFTP*, *SSH-2* sur les points d'accès internes et externes.

Un registre clair sera créé pour documenter les procédures de gestion et de contrôle de la

sécurité des données personnelles pour assurer un système de responsabilisation et de respect de la Politique Interne de Protection des Données d'Amazon ("DPP").

Le responsable devra maintenir et mettre à jour un inventaire précis des actifs logiciels et appareils ayant accès aux données personnelles. Le responsable implémentera également un contrôle des versions des logiciels ayant accès aux données personnelles avec des tests de qualité automatisés en utilisant notamment des pipelines d'intégrations et de développement continu, et un système de pull requests empêchant le déploiement des nouvelles versions des logiciels sans une revue du code préalable pour approuver les changements.

Le responsable documentera la traçabilité des données stockées dans le système de gestion de base de données avec un système de labellisation sur *PostgreSQL*, *Redshift* et *Jira*.

Dans le cadre du renforcement de la sécurité de l'application, des systèmes d'évaluations annuelles de la vulnérabilité, des risques et potentielles menaces des réseaux seront mis en place avec notamment des rapports de *Contrôles de l'Organisation et des Systèmes* (SOC2). Des plans d'actions pour répondre aux brèches de sécurité seront mis en place pour notifier Amazon sous 24 heures après avoir détecté une brèche.

Le responsable de l'application effacera les données personnelles sous 30 jours en cas de réception d'un avis d'*Amazon* à moins que les données soient nécessaires pour répondre aux besoins légaux notamment en matière de taxe et de réglementation. De plus, le responsable devra supprimer les instances de l'application sous 90 jours en cas d'une demande explicite d'Amazon.

L'application ne sera pas pour l'instant exposée aux utilisateurs d'*Amazon* directement via la boutique d'applications des partenaires de vente.

Les actifs physiques qui stockent et manipulent les données personnelles doivent répondre aux exigences de la Politique de Protection des Données d'Amazon ("DPP"). Le responsable ne doit pas stocker les données personnelles sur des media amovibles, des appareils personnels et services de cloud non sécurisés à moins que ces données aient été préalablement cryptées avec un système de chiffrement utilisant des clés AES-128 ou RSA-2048. De plus, le responsable doit s'assurer de la suppression de documents imprimés contenant les données personnelles. Enfin, le responsable doit mettre en place des systèmes de prévention de perte de données ("DLP") pour mieux surveiller et détecter les flux de données non autorisées.

B) Procédures d'accès aux données personnelles collectées

Des instances *Quicksight* et *Toucan* seront connectées aux bases de données *PostgreSQL* et *Redshift* via une connexion d'utilisateur applicatif. L'administrateur de la base de données, Clément Msika, accordera des droits de lecture seule restreints à cet utilisateur applicatif.

Des systèmes de réplication seront implémentés avec *PostgreSQL* et *Redshift* pour renforcer la sécurité des données et optimiser la performance des dashboards *Quicksight* et *Toucan*. L'accès aux données *PostgreSQL* via les connecteurs *PostgreSQL* de *Quicksight* et *Toucan* s'effectuera sur la connexion *slave* tandis que la modification et l'insertion des données se réalisera sur la connexion *master*. Les données seront agrégées dans des tables spécifiques pour optimiser la performance des dashboards en termes de latence, de rafraîchissement des données. Des accords de niveau de services seront réalisés pour renforcer la fiabilité des produits analytics développés à un usage interne.

De plus, les workflows liés aux scripts *ETL* et mise à jour des objets *Selling Partner* et *Sponsored Products* via l'*API* seront déployés avec *Kubernetes* pour encapsuler le code, optimiser la maintenance des outils et la dépendance des librairies.

Par ailleurs, un système d'envoi par mail des rapports analytics liés aux commandes, prévision des stocks et de la demande sera effectué en utilisant les fonctionnalités de *Quicksight* et *Toucan*. Les données de performance financières seront accessibles depuis des fichiers *Excel* mis en pièce-jointe des mails.

Un système sécurisé de gestion des identifiants de *PostgreSQL* et *Redshift* sera également mis en place pour sécuriser l'accès à l'application avec notamment des mécanismes d'accès aux ressources très granulaires suivant le principe du moindre privilège. Les clés API ne seront accessibles que par le responsable de l'application. Un système d'authentification à plusieurs facteurs (*MFA*) est également implémenté pour renforcer l'accès au compte *Amazon Seller* de l'application.

IV) Types de Données Personnelles Collectées

Les données personnelles collectées exclusivement via l'*API Selling Partner* d'Amazon concernent les acheteurs des objets mis en vente par la librairie *Les Livres de la Mer* et les vendeurs des produits achetés par la boutique.

Ces données seront limitées aux noms, prénoms, coordonnées géographiques (code postal, adresse, pays, adresse IP), les adresses mail, segments socio-démographiques, coordonnées bancaires, données d'attribution (appareils utilisés, navigateur web, user agent, application mobile, identifiants uniques customer ID et vendor ID *Amazon*), historique des transactions, données d'enquêtes de satisfaction, contenu des messages cadeaux.

V) Parties Externes avec Lesquelles L'Organisation Partage les Données Personnelles

La base de données *PostgreSQL*, et l'entrepôt de données *Redshift* hébergés sur *AWS* stockant les données personnelles seront exclusivement accessibles au responsable de la boutique, Clément Msika, ainsi qu'à *Amazon*.

Les dashboards *Quicksight* et *Toucan* développés par Clément Msika pour visualiser les données collectées ne seront pas partagés avec d'autres utilisateurs.

Le responsable de la boutique, Clément Msika, sera l'utilisateur unique de ces données personnelles.

Les analyses et insights liés à ces données personnelles auront uniquement un usage interne pour le responsable de la boutique *Les Livres de la Mer*.

VI) Responsable du Traitement

Le seul et unique responsable du traitement des données personnelles collectées est le vendeur et acheteur marketplace Clément Msika présent sur Amazon France, via le site ou l'application, à travers la boutique *Les Livres de la Mer*.

Son adresse est détaillée ci-dessous:

50 Rue Falguière
Deuxième étage
75015 Paris
France

VII) Droits des Utilisateurs dont Les Données Personnelles sont Collectées, Stockées et Analysées

Les utilisateurs représentent ici les vendeurs et acheteurs *Amazon* en relation avec la boutique *Les Livres de La Mer* gérée par Clément Msika et présente sur le site et l'application *Amazon France*.

Les utilisateurs ont consenti à partager leurs données personnelles avec *Amazon*. Cette collecte du consentement est détaillée sur [la notice de protection des informations personnelles](#). Les utilisateurs ont le droit d'accéder à ces informations sur demande en contactant Amazon sur l'adresse mail eu-privacy@amazon.fr.

Les utilisateurs dont les données personnelles sont traitées ont également le droit de modifier leurs préférences en matière de consentement.

Le responsable de la librairie *Les Livres de la Mer* sera tenu de répondre aux demandes légales d'*Amazon* dans le cas où *Amazon* exige de supprimer ces données personnelles ou de modifier la politique de rétention des données personnelles fixée par défaut à 30 jours.

Un audit annuel des données personnelles stockées et archivées sera effectué par le responsable de la librairie pour s'assurer du respect des accords d'utilisation des API d'Amazon ("Amazon Services API Developer Agreement"), de la Politique de Protection des données d'Amazon ("DPP") et de la Politique d'Utilisation Acceptable ("AUP") dans le cadre de la réglementation applicable de protection des données.